

Vendor Information Security Assessment Procedure

CONTROLLED DOCUMENT - SYNTHETIC ENTERPRISE CONTENT FOR RAG TESTING

Document ID	PROC-001	Version	1.0
Owner / Department	Third-Party Risk	Effective date	2026-02-20
Access groups	Procurement;Security;Legal	Classification	Internal

Purpose and scope

This procurement document establishes a consistent operating standard for Northstar Chain Systems. It applies to personnel in the listed access groups and to approved contractors when they perform work on behalf of the company. Managers are accountable for local adoption; the document owner maintains the standard and annual review cycle.

Assessment Triggers

Standard. It is required before onboarding a vendor that will access company or customer Confidential data. The control exists to make decisions traceable, protect customers and employees, and give teams a predictable operating baseline.

Procedure. Staff should follow the approved workflow, record required approvals in the system of record, and raise exceptions before acting. The accountable owner may provide implementation guidance that is consistent with this standard.

Risk Tiers

Standard. Vendors processing Restricted data receive a Tier 1 assessment. The control exists to make decisions traceable, protect customers and employees, and give teams a predictable operating baseline.

Procedure. Staff should follow the approved workflow, record required approvals in the system of record, and raise exceptions before acting. The accountable owner may provide implementation guidance that is consistent with this standard.

Risk Acceptance

Standard. The business owner and Chief Information Security Officer must accept residual high risk. The control exists to make decisions traceable, protect customers and employees, and give teams a predictable operating baseline.

Procedure. Staff should follow the approved workflow, record required approvals in the system of record, and raise exceptions before acting. The accountable owner may provide implementation guidance that is consistent with this standard.

Roles, exceptions, and evidence

The Third-Party Risk team is the policy owner. Questions and requested exceptions must be submitted through the service portal or designated owner channel. Exceptions require documented business rationale, risk assessment where relevant, and an expiry date. Evidence of compliance must be retained in the appropriate company system and provided during an authorized review.

Review and enforcement

This document is reviewed at least annually or sooner when legal, regulatory, operational, or material-risk changes occur. Failure to follow this standard may result in removal of access, corrective action, or escalation under the Company Code of Conduct.